Vale Banking Mini Project: Build Plan (Draft)

Overview

The mini project is using my Week 3 **Vale** Figma design into a working UIKit app connected to a mock REST API. It answers the mini project brief: integrate the UI and API layers into one app with end-to-end user workflows, secure local storage and encryption checkpoints, and real-time state updates.

It reuses what I practiced in earlier weeks: the MVVM folder structure from the Week 2 Own Account Transfer app, the REST and Mockoon setup from the Week 4 Users exercise, and the OWASP MASVS checklist from my Week 1 plan.

	In scope	Out of scope
Platform	iOS, UIKit, MVVM, iPhone Simulator	iPad layouts
Screens	Login, Verification, Home, Cards, Dashboard, Profile, plus a Transfer sheet	Pay, card limits, Add to Wallet, PIN change (shown as "coming soon")
Backend	Mockoon "Vale API" on port 3002	A real server or database
Security	Keychain token, auto logout, privacy cover, masked numbers	Face ID, encrypted offline cache, certificate pinning

Requirements

The app must support seven end-to-end workflows, each finishing with the API and the UI in agreement.

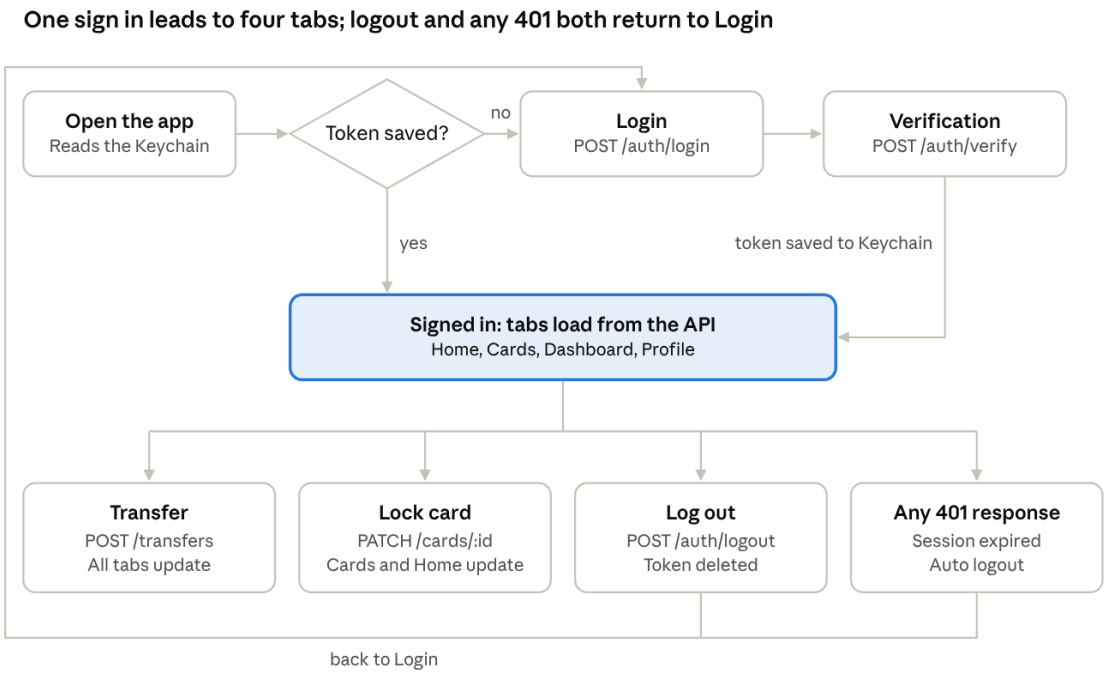
#	Workflow	Screens	Done when
1	Sign in, 2 steps	Login → Verification → Home	Correct password and code open Home; a token is saved in the Keychain
2	Load my money	Home, Cards, Dashboard, Profile	Balances, card, payments and spending load from the API
3	Transfer between my accounts	Home → Transfer → Home	Both balances and the payment history update on every screen
4	Lock or unlock my card	Cards	The card status changes on Cards and Home without a reload
5	Log out	Profile → Login	Token deleted, data cleared, Login shown
6	Session expires	Any → Login	Any 401 logs out with "Your session has expired"
7	Stay signed in	Relaunch → Home	A saved token skips the login

Non-functional requirements:

- **Security:** follow the MASVS checkpoints in the Security section.
- **Real-time state:** one shared store; every screen redraws when the data changes.
- **Error handling:** clear messages for network errors, 4xx and 5xx responses and bad JSON, plus a retry or pull-to-refresh.
- **UX:** match the Figma colours and layout, Dynamic Type labels, VoiceOver labels, 44pt touch targets, loading states on every button that calls the API.

End-to-end user workflows

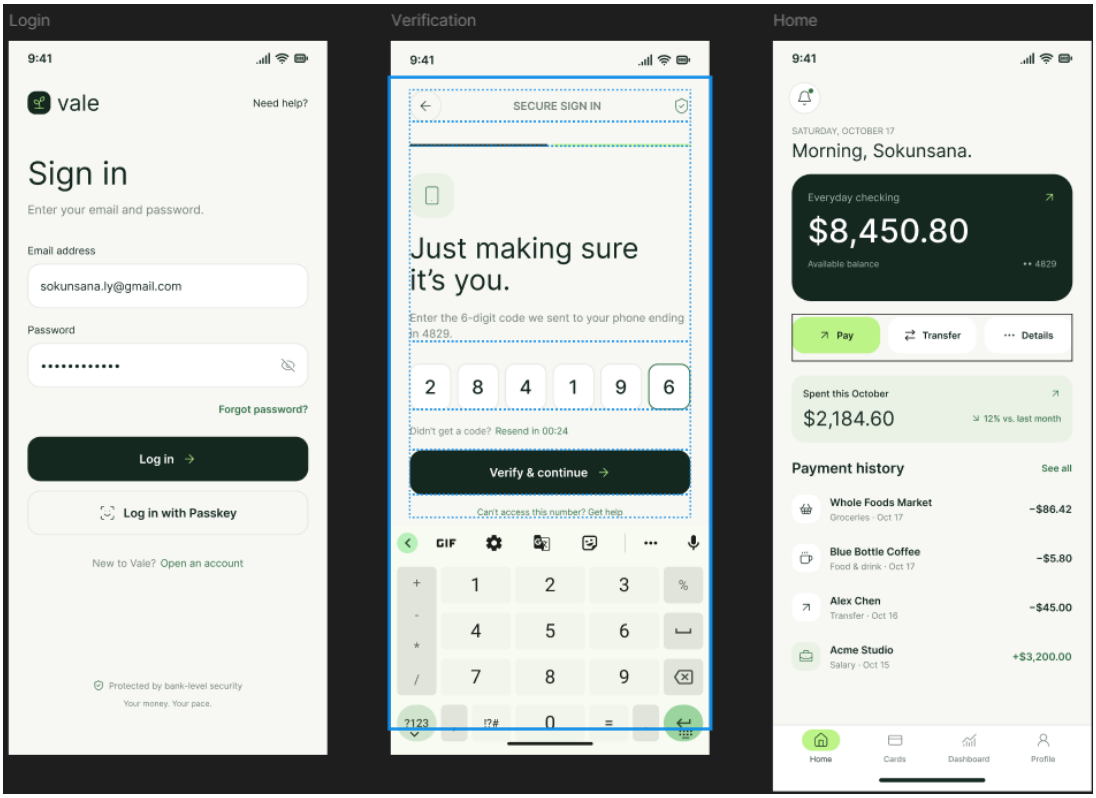
Every workflow runs through the real UI, the API and secure storage, from opening the app to signing out.

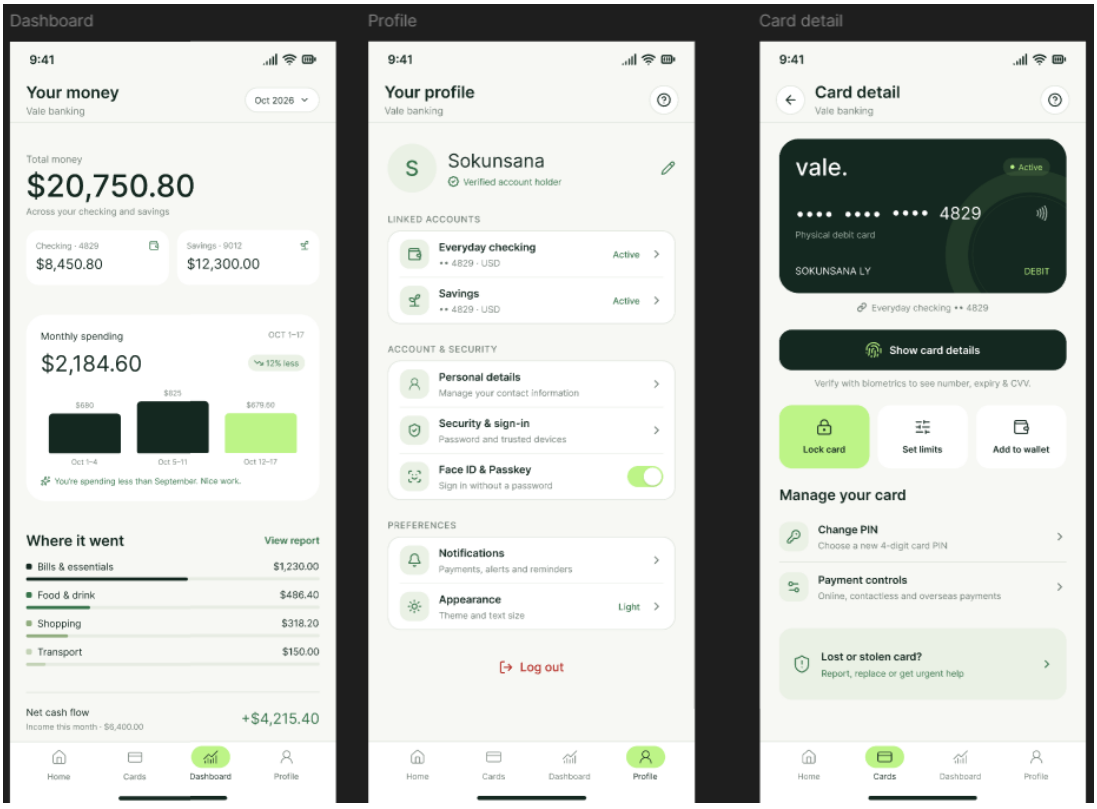


End-to-end workflows: sign in to logout

A saved token skips the login on relaunch. After sign in, a transfer or card lock updates every tab at once, and both a manual logout and an expired session (any 401) delete the token and return to Login.

Figma Design





Integrated feature and security checkpoint validation

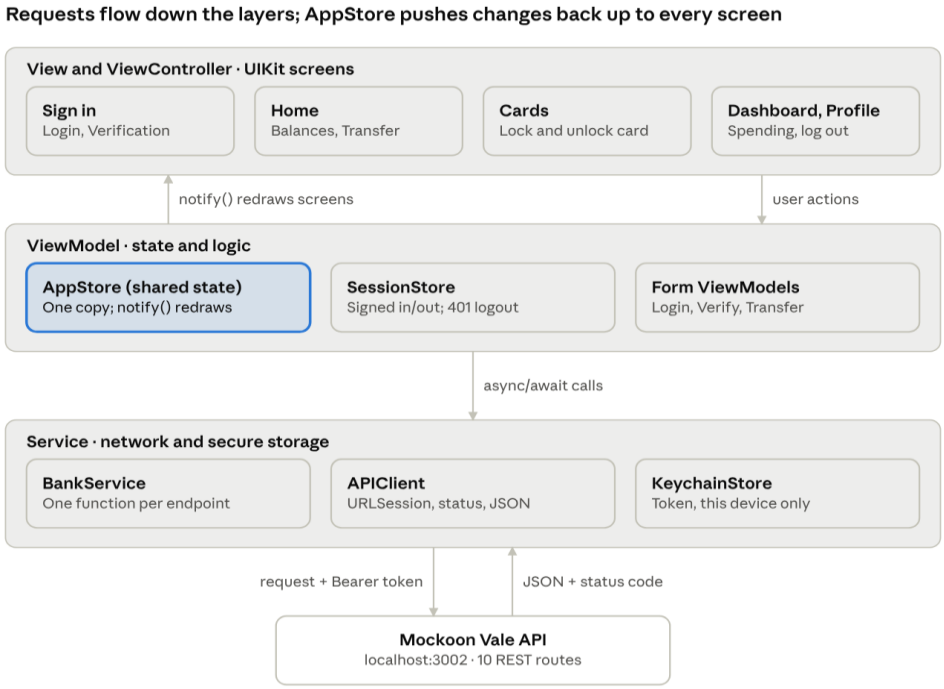
Security is built into each feature rather than added at the end, so every feature is validated together with the checkpoint it carries. Each row is one test run on the Simulator with Mockoon, and its status is updated as the tests pass.

Feature	Security checkpoint built in	MASVS	How it is validated	Status
Sign in, step 1	Password checked by the API, never stored, cleared after the step	AUTH, STORAGE	Wrong password shows an error; no password found in app storage	Not run
Verification code	A one-time code is required before any token is issued	AUTH	`111111` is rejected with no token; `123456` opens Home	Not run
Token storage	Token saved in the Keychain, this device only	STORAGE	Relaunch stays signed in; no token in UserDefaults	Not run
Loading data	Bearer token on every request; no responses cached on disk	AUTH, STORAGE	Mockoon Logs show the `Authorization` header on each GET	Not run
Session expiry	Any 401 logs out, deletes the token and clears data	AUTH	Change the token rule on `/accounts`, refresh: Login shows "session expired"	Not run
Transfer	Amount checked before sending; `Idempotency-Key` on the request	RESILIENCE	Over-balance amount blocked with no API call; Logs show the key	Not run
Card lock	Locked card hides details; only the last 4 digits are ever shown	PRIVACY	Lock disables Show card details; number shows `•••• 4829`	Not run
Log out	Server logout, token deleted, data cleared from memory	AUTH, STORAGE	Log out, relaunch: the app opens on Login	Not run
App switcher	Privacy cover hides balances in the snapshot	PRIVACY	Open the app switcher: dark Vale cover, no balances	Not run
Network	HTTPS enforced; only `localhost` allowed over http	NETWORK	Point the base URL at an http website: the request is blocked	Not run
Debug	Logs show method, path	CODE	Xcode console has no token, password or	Not run

Feature	Security checkpoint built in	MASVS	How it is validated	Status
logging	and status only		response body	

Architecture

The app keeps the Week 2 MVVM folders and adds a Service layer, so no screen ever talks to the network directly.



MVVM layers: screens to Mockoon

A screen asks a ViewModel, the ViewModel calls BankService, and APIClient sends the request with the token from the Keychain. When data changes, AppStore calls `notify()` and every observing screen redraws, which is how a transfer updates Home, Dashboard and Profile at once.

API design

The backend is a Mockoon environment, "Vale API", with 10 REST routes on `http://localhost:3002`. Every data route checks the `Authorization: Bearer` header and returns 401 without a valid token, so the app's auto logout can be tested against a real rule.

Method	Path	Auth	Success	Errors to handle
POST	`/auth/login`	None	200 `{challengeId, phoneLast4}`	401 wrong

Method	Path	Auth	Success	Errors to handle
				password
POST	`/auth/verify`	None	200 `{accessToken, tokenType, expiresIn}`	401 wrong code
GET	`/me`	Bearer	200 user profile	401
GET	`/accounts`	Bearer	200 checking and savings	401
GET	`/cards`	Bearer	200 debit card	401
PATCH	`/cards/:id`	Bearer	200 card with the new status	401
GET	`/transactions`	Bearer	200 payment history	401
GET	`/insights/spending`	Bearer	200 Dashboard numbers	401
POST	`/transfers`	Bearer	201 completed transfer	401, 422 declined
POST	`/auth/logout`	Bearer	204 no body	401

Demo values for testing: password `Vale@2026`, code `123456`, and a transfer note of `decline` to force a 422. The environment file is committed with the app as `Mockoon/vale-api.json`.

Security and compliance checkpoints

Each checkpoint maps to an OWASP MASVS area from my Week 1 plan and to the file that implements it, so a reviewer can verify it.

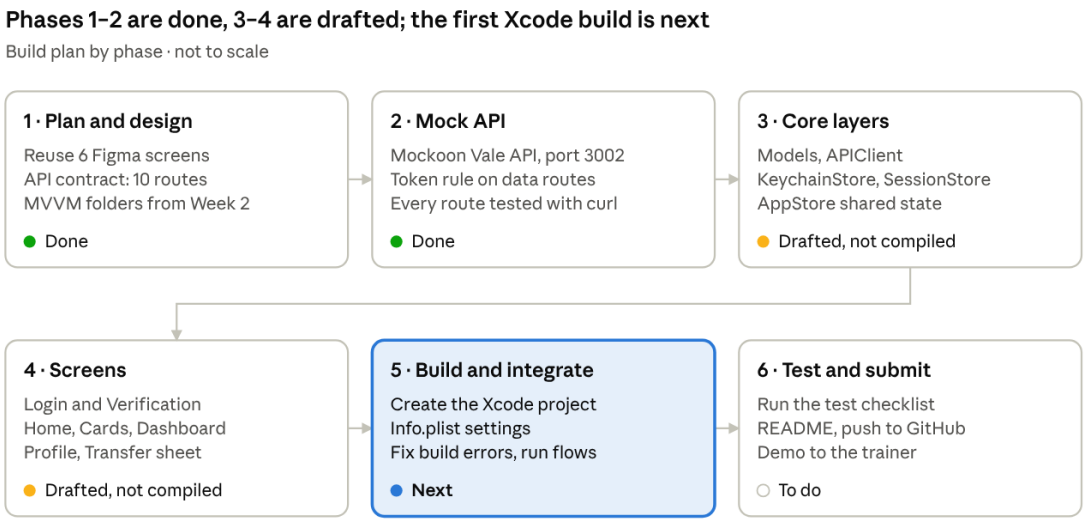
MASVS area	Checkpoint	Where
STORAGE	Access token in the Keychain with `WhenUnlockedThisDeviceOnly`; never in UserDefaults or files	`KeychainStore.swift`
STORAGE	Password never stored; cleared from the field after step 1	`SessionStore`, `LoginViewController`
STORAGE	No response caching on disk (ephemeral URLSession, no URL cache)	`APIClient.swift`
AUTH	Two-step sign in (password, then one-time code); Bearer token on every data request	`SessionStore`, `APIClient`
AUTH	Auto logout on any 401, plus manual logout; token deleted and data cleared	`APIClient`, `SessionStore`

MASVS area	Checkpoint	Where
NETWORK	App Transport Security stays on; only `localhost` allowed over http for the mock	Info.plist
PRIVACY	Account and card numbers masked (`•• 4829`); full card details gated behind biometrics	`Format`, `DebitCardView`
PRIVACY	App-switcher snapshot covered so balances aren't visible	`SceneDelegate`
CODE	Debug logs show method, path and status only; nothing logged in Release	`APIClient`
CODE	No hard-coded secrets; the base URL lives in one config file	`AppConfig.swift`
RESILIENCE	`Idempotency-Key` header on transfers so a retry can't move money twice	`BankService`

Data in transit is encrypted by HTTPS in a real deployment; the http exception exists only because Mockoon runs locally.

Build phases

The build runs in six phases. Phases 1 and 2 are complete and tested, 3 and 4 are drafted as code, and the next step is the first Xcode build.



Build plan · 6 phases

Each phase ends with a check before the next starts: the API is tested with curl before any Swift is written, and the app must build and pass the sign-in flow before the full test checklist runs. Dates are left open until the submission date is confirmed.

Testing plan

Testing follows the SDLC test types from my Week 1 plan, scaled down to one developer and a mock server. Every case runs on the iPhone Simulator with Mockoon started.

Test type	Case	How	Expected result
Unit	Amount validation	`TransferViewModel.validationError` with 0, too much, 3 decimals	A message for each; valid amounts pass
Unit	Money and date formatting	`Format.money`, `signedMoney`, `shortDate`	`$8,450.80`, `−$86.42`, `Oct 17`
SIT	Wrong password	Any password except `Vale@2026`	"Incorrect email or password.", red fields
SIT	Wrong code	`111111`	Boxes shake and clear; error shown
SIT	Transfer	$100 checking → savings	Home, Dashboard and Profile balances update at once
SIT	Declined transfer	Note `decline`	422 message; balances unchanged
SIT	Lock card	Cards → Lock card	Locked on Cards; "Card locked" on Home
Security	Auto logout	Change the token rule on `/accounts` in Mockoon, then refresh	Back to Login with "Your session has expired"
Security	Token persistence	Relaunch the app	Opens on Home; token still in the Keychain
Security	Privacy cover	Open the app switcher	Dark Vale cover, no balances
Regression	Server down	Stop Mockoon, pull to refresh	"Can't reach Vale right now"; old data stays
UAT	Walkthrough with trainer	Sign in → transfer → lock card → log out	Matches the Figma flow; feedback logged

Assumptions: the mock API stands in for a real bank server, and demo credentials are acceptable for a training project.

Open questions for the trainer:

- ☐ What is the submission date, and is a live demo expected?
- ☐ Are unit tests required in an Xcode test target, or is the manual checklist enough?

- ☐ Is it expected to make the project in both Kotlin and Swift?